NEXUS FINANCIAL

Penetration Testing Report

Microsoft 365 and Entra ID Security Assessment
Conducted by: ClearPath Security Ltd
Commissioned by: Nexus Financial
Assessment: October 2025 | Report Date: November 2025
Classification: Highly Confidential

1. Executive Summary

ClearPath Security Ltd was engaged by Nexus Financial to conduct a security assessment of the Microsoft 365 environment and Entra ID identity platform in October 2025.

Assessment Scope

In Scope:

• Exchange Online -- email security and configuration

• SharePoint Online -- permissions and external sharing

• Microsoft Teams -- data sharing and guest access

• Entra ID -- identity, authentication, and access policies

• SIEM detection rule coverage for Microsoft 365 threat scenarios

Out of Scope:

• On-premises servers and network devices

• Physical security controls

• Third party applications not hosted in Microsoft 365

• End user devices and endpoint security

Findings Summary

Critical: 0 | **High:** 2 | **Medium:** 3 | **Low:** 1

All findings listed below remain open and unaddressed as of March 2026.

Nexus Financial was notified in November 2025. The two High severity findings have been outstanding for over four months.

2. Findings Summary Table

Ref	Title	Severity	Status
NXF-PT-001	MFA Not Enforced on Standard User Accounts	High	Open
NXF-PT-002	Email Authentication Controls Not Configured (SPF, DKIM, DMARC)	High	Open
NXF-PT-003	No External Email Origin Warning Banner	Medium	Open
NXF-PT-004	SharePoint Permissions Not Reviewed	Medium	Open
NXF-PT-005	SIEM Detection Rules Do Not Cover Key M365 Threat Scenarios	Medium	Open
NXF-PT-006	Security Awareness Training Not Completed by All Staff	Low	Open

3. Detailed Findings

NXF-PT-001: Multi-Factor Authentication Not Enforced on Standard User Accounts

Severity: High
Affected Service: Entra ID -- All standard user accounts
Status: Open -- Not remediated as of March 2026

Multi-Factor Authentication (MFA) is not enforced for standard user accounts in the Nexus Financial Entra ID environment. During testing, the assessment team was able to authenticate to multiple user accounts using only a username and password combination with no secondary verification required.

MFA is one of the most effective controls available for preventing unauthorised account access. Without it, a stolen or phished password is sufficient for an attacker to gain full access to a user's email, files, and cloud resources.

Recommendation: Enforce MFA for all user accounts via an Entra ID Conditional Access Policy. Prioritise accounts with access to sensitive data in Finance and HR.

NXF-PT-002: Email Authentication Controls Not Configured (SPF, DKIM, DMARC)

Severity: High
Affected Service: Exchange Online -- nexusfinancial.com domain DNS records
Status: Open -- Not remediated as of March 2026

The nexusfinancial.com domain does not have SPF, DKIM, or DMARC records configured. The absence of these controls means that receiving mail servers have no mechanism to verify whether an email associated with nexusfinancial.com is legitimate.

SPF defines which mail servers are authorised to send email on behalf of a domain. DKIM provides a cryptographic signature to verify email content has not been tampered with. DMARC builds on both and specifies what action receiving servers should take when an email fails these checks.

Without these controls, attackers can register lookalike domains visually similar to nexusfinancial.com and send phishing emails from them. Receiving mail servers have no policy to quarantine or reject such emails, meaning they are delivered directly to employee inboxes.

Recommendation: Publish an SPF TXT record. Enable DKIM signing via Exchange Online. Implement a DMARC policy starting at p=none, then progressing to p=quarantine or p=reject once validated.

NXF-PT-003: No External Email Origin Warning Banner Configured

Severity: Medium
Affected Service: Exchange Online -- All inbound email
Status: Open -- Not remediated as of March 2026

Emails from outside the Nexus Financial domain are delivered without any visual indicator distinguishing them from internal emails. Test phishing emails from external domains were visually indistinguishable from legitimate internal communications.

Recommendation: Configure an Exchange Online mail flow rule to prepend an external sender warning to all emails from outside nexusfinancial.com.

NXF-PT-004: SharePoint Permissions Not Reviewed Since Initial Setup

Severity: Medium
Affected Service: SharePoint Online -- Finance and HR sites
Status: Open -- Not remediated as of March 2026

SharePoint permissions for Finance and HR departments have not been reviewed since initial setup. Several accounts have access beyond their role requires.

External sharing is enabled by default on both sites with no restrictions on which domains can receive shared content.

Recommendation: Review all SharePoint site permissions. Apply the principle of least privilege. Restrict or disable external sharing for sensitive sites.

NXF-PT-005: SIEM Detection Rules Do Not Cover Key Microsoft 365 Threat Scenarios

Severity: Medium
Affected Service: Splunk Cloud -- SIEM detection rule set
Status: Open -- Not remediated as of March 2026

The current SIEM detection rule set does not include alerts for the following high-priority Microsoft 365 threat scenarios:

• Inbox rule creation on Exchange Online accounts

• Bulk file downloads from SharePoint within a short timeframe

• User sign-in from a country not previously associated with that account

• External sharing of files to personal email domains

• Multiple failed sign-in attempts followed by a successful sign-in

An attacker who gains access to a user account could carry out post-compromise activity for an extended period before being detected by the SOC team.

Recommendation: Implement detection rules for each scenario listed above. Assign ownership to the SOC Manager and schedule quarterly reviews.

NXF-PT-006: Security Awareness Training Not Completed by All Staff

Severity: Low
Affected Service: Organisation-wide
Status: Open -- Not remediated as of March 2026

34% of Nexus Financial employees have not completed the mandatory annual security awareness training module including phishing recognition, password hygiene, and incident reporting procedures.

Recommendation: Mandate completion for all staff. Run simulated phishing campaigns to assess and improve awareness levels.

4. Remediation Timeline

Finding	Severity	Recommended Window
NXF-PT-001	High	Immediate -- within 30 days
NXF-PT-002	High	Immediate -- within 30 days
NXF-PT-003	Medium	Short term -- within 60 days
NXF-PT-004	Medium	Short term -- within 60 days
NXF-PT-005	Medium	Short term -- within 60 days
NXF-PT-006	Low	Ongoing

End of Document